



PS-NC-022

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v01 – Diciembre 2024

	Responsable	Fecha	Firma
Elaborado	Pablo Torres - José Villa.	18.12.2024.	
Revisado	Catalina Araya Carlos Valdovinos - José Villa.	18.12.2024.	
Aprobado	Jorge Herrera.	19.12.2024.	



POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 2 de 36	TLP: BLANCO

Contenido

1	PROPOSITO.....	4
2	ALCANCE O AMBITO DE APLICACIÓN.	4
3	DEFINICIONES.....	4
4	MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS.	5
	▪ Documentos Relacionados.	5
	▪ Leyes o Decretos.	5
5	ROLES Y RESPONSABILIDADES.....	7
6	MATERIAS QUE ABORDA.	8
7	DIRECTRICES DE LA POLÍTICA.	8
7.1	Arquitectura de seguridad basada en principios de seguridad.....	8
7.1.1	Modelo de Confianza Zero	9
7.1.2	Seguridad desde el Diseño ("Security by Design").	9
7.1.3	Segmentación de Redes y Microsegmentación.	9
7.2	Gestión de Identidad.....	10
7.2.1	Principio de Mínimo Privilegio.	10
7.2.2	Acceso Multi Factor MFA.	10
7.2.3	Uso de Roles en lugar de Credenciales Estáticas.	10
7.3	Gestión de claves y el uso de técnicas de tokenización.	11
7.3.1	Cifrado de Datos en Transito y en Reposo:	11
7.3.2	Gestión Segura de Claves (AWS KMS, Azure Key Vault, Google Cloud KMS):	11
7.3.3	Tokenización y Enmascaramiento de Datos Sensibles.	12
7.4	Geolocalización y Protección de Datos Sensibles.	12
7.4.1	Geolocalización y Protección de Datos Sensibles.	12
7.4.2	Diseño de Alta Disponibilidad y Recuperación ante Desastres.	13
7.4.3	Uso de Múltiples Zonas de Disponibilidad (AZ) y Regiones.	13
7.4.4	Automatización de Failover y Backups Regulares.	14
7.4.5	Administración de la información de autenticación secreta de los usuarios (usuario y contraseña).	14

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 3 de 36	TLP: BLANCO

7.4.6	Uso de Herramientas SIEM (Security Information and Event Management):	14
7.4.7	Análisis de Comportamiento de Usuarios y Entidades (UEBA):	14
7.4.8	Monitoreo Proactivo y Respuesta Automática a Eventos:	15
7.4.9	Gestión de Vulnerabilidades y Actualización de Seguridad:	15
7.4.10	Almacenamiento en Nube:	16
7.5	Pruebas de Seguridad y Auditoría.	18
7.5.1	Pruebas de Penetración y Auditorías de Terceros.....	18
7.5.2	Metodología de simulación de Red Team y Ethical Hacking:	18
7.5.3	Revisiones de Arquitectura de Seguridad.	19
7.6	Almacenamiento en Nube:	19
7.6.1	Uso de servicios de almacenamiento en nubes públicas.	19
7.6.2	Lista de servicios de almacenamiento en la nube permitidos.....	20
7.6.3	Proceso de eliminación de información:	21
7.6.4	Copias de seguridad en la nube	21
7.6.5	Auditoría y Supervisión Post-Contratación.....	22
7.7	Contratación de servicios en Nube:	23
7.7.1	Medidas organizativas.	26
7.7.2	Medidas técnicas.	27
7.7.3	Resguardos de legalidad de las cláusulas:.....	31
8	PROPIEDAD INTELECTUAL EN ENTORNOS CLOUD:	31
9	MECANISMO DE DIFUSIÓN:	32
10	PERÍODO DE REVISIÓN:	32
11	EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA:	32
12	HISTORIAL Y CONTROL DE VERSIONES:	33
13	ANEXO Cloud Security Comparison: AWS vs Azure vs GCP:.....	33

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 4 de 36	TLP: BLANCO

1 PROPOSITO.

Establecer los lineamientos y requisitos de seguridad específicos para la gestión y protección de los entornos de nube pública utilizados por el Ministerio de Salud (Minsal). Esta política define los controles y prácticas necesarias para asegurar la confidencialidad, integridad y disponibilidad de la información crítica almacenada y procesada en la nube, minimizando los riesgos de seguridad y garantizando la resiliencia operativa frente a incidentes. Además, promueve una estructura de seguridad alineada con normativas y estándares reconocidos, en apoyo al cumplimiento de las políticas de seguridad de la información de Ministerial.

2 ALCANCE O AMBITO DE APLICACIÓN.

Esta política aplica a todos los recursos, aplicaciones, servicios, datos y usuarios que interactúan con los entornos de nube pública del Minsal, incluyendo los servicios de AWS, Azure y GCP. También es aplicable a cualquier proveedor, funcionario o personal que tenga acceso a estos entornos.

Alcance de Dominios y Controles de Seguridad de la Información		
Estándar	ID Control	Nombre del Control
ISO 27001:2022 - Controles Organizacionales	5.16	Gestión de Identidad
	5.17	Información de Autenticación
	5.18	Autenticación de usuarios
	5.19	Gestión de acceso privilegiado
ISO 27001:2022 - Tecnología	8.5	Autenticación Segura
	8.6	Gestión de accesos a la red
	8.7	Gestión de accesos a sistemas operativos
	8.8	Gestión de accesos a aplicaciones

3 DEFINICIONES.

- **Modelo de Responsabilidad Compartida:** Divisiones de responsabilidades entre el proveedor de servicios en la nube y el cliente.
- **SAS (Software as a Service):** Servicio en la nube que ofrece aplicaciones completas accesibles vía internet sin necesidad de instalación ni mantenimiento por parte del cliente.
- **PAS (Platform as a Service):** Servicio en la nube que proporciona una plataforma para desarrollar, ejecutar y gestionar aplicaciones sin preocuparse por la infraestructura subyacente.
- **IAS (Infrastructure as a Service):** Servicio en la nube que ofrece recursos virtualizados como máquinas, almacenamiento y redes, permitiendo al cliente gestionar las aplicaciones y configuraciones.
- **Nube Pública:** Infraestructura de servicios en la nube compartida por múltiples

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 5 de 36	TLP: BLANCO

organizaciones y gestionada por un proveedor externo (AWS, Azure, GCP).

- **Nube Privada:** Infraestructura de servicios en la nube utilizada exclusivamente por una organización, ya sea gestionada internamente o por un tercero.
- **Nube Híbrida:** Modelo que combina nubes públicas y privadas, permitiendo la transferencia de datos y aplicaciones entre ellas.
- **Proveedor de Servicios en la Nube:** Entidad que ofrece servicios en la nube como almacenamiento, plataformas o infraestructura (AWS, Azure, GCP).
- **Cloud Computing:** Modelo que permite acceder a recursos tecnológicos (como almacenamiento, aplicaciones y procesamiento) a través de internet, sin necesidad de gestionar infraestructura física local.
- **Servicios Cloud:** Soluciones tecnológicas ofrecidas en la nube que incluyen almacenamiento, plataformas y aplicaciones.

4 MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS.

- **Marco Normativo.**
 - NCh ISO27001:2022: Seguridad de la información, ciberseguridad y protección de la privacidad – Controles de seguridad de la información.
 - Norma ISO/IEC 27017 que proporciona controles y asesoramiento para la implementación, tanto para proveedores de servicios en la nube.
 - El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.
- **Documentos Relacionados.**
 - Documento del Sistema de Gestión de Seguridad de la Información, disponibles en isalud.minsal.cl.
- **Leyes o Decretos.**
 - Ley N° 19.628, de Protección de vida privada y datos personales¹.
 - Ley N° 20.285, de 2008, Ministerio Secretaría General de la Presidencia, sobre acceso a la información pública.
 - Ley N° 20.584, de 2012, Ministerio de Salud, Subsecretaría de Salud Pública, regula derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud.
 - Ley N° 21.459, que establece normas sobre delitos informáticos, deroga la ley N° 19.223 y modifica otros cuerpos legales con el objeto de adecuarlos al Convenio de Budapest.
 - Ley N° 21.180, Ley de Transformación Digital del Estado, establece directrices para la modernización de los procesos y servicios digitales en instituciones

¹ La Ley N° 21.719, de 2024, modifica la Ley N° 19.628, entrará en vigor el 01 de diciembre de 2026.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 6 de 36
TLP: BLANCO				

públicas. Tiene implicaciones en la privacidad y la protección de datos personales, ya que establece estándares para la seguridad de la información en servicios y plataformas digitales, fomentando la eficiencia sin comprometer la confidencialidad y la integridad de los datos de los ciudadanos.

- Ley 21.541, que modifica la normativa que indica para autorizar los prestadores de salud a efectuar atenciones mediante telemedicina.
- Ley N° 21.663 sobre Marco de Ciberseguridad, esta ley proporciona un marco para asegurar la ciberseguridad de infraestructuras críticas, que indirectamente impacta en la protección de datos.
- Ley 21.668, que establece la interoperabilidad de las fichas clínicas, sobre protección de datos establece un marco legal para salvaguardar la privacidad y los derechos de los ciudadanos en relación con sus datos personales.
- Ley N° 19.886, ley de compras y contratación pública.
- Decreto N° 41 de 2012, del Ministerio de Salud, que aprueba reglamento sobre fichas clínicas.
- Decreto 273, de 2022, del Ministerio del Interior, que establece la obligación de reportar incidentes de ciberseguridad a los organismos del Estado al CSIRT de gobierno.
- Decreto N° 6, de 2021, del Ministerio de Salud, Reglamento sobre acciones vinculadas a la atención de salud realizada a distancia.
- Decreto supremo N° 40, de 2012, del Ministerio de Salud, que aprueba reglamento sobre requisitos básicos que deberán contener los reglamentos internos de los prestadores institucionales públicos y privados para la atención en salud de las personas de la ley N° 20.584;
- Decreto supremo N° 38, de 2012, del Ministerio de Salud, que aprueba reglamento sobre derechos y deberes de las personas en relación con las actividades vinculadas con su atención de salud.
- Decreto supremo N° 7, de 2019, del Ministerio de Salud, que aprueba el reglamento sobre notificación de enfermedades transmisibles de declaración obligatoria y su vigilancia
- Decreto N° 533, de 2015, del Ministerio del Interior, Subsecretaría del Interior, que crea Comité Interministerial sobre Ciberseguridad y establece el marco regulatorio en ciberseguridad para las instituciones públicas en Chile, que incluye normas para la protección de la información, la gestión de incidentes de ciberseguridad y la protección de infraestructuras críticas, en las que se procesan datos personales.
- Decreto N° 20, que aprueba Política Nacional de Inteligencia Artificial.
- Decreto Supremo N° 7 establece una Norma Técnica de Seguridad de la Información y Ciberseguridad, en concordancia con la Ley N° 21.180 sobre Transformación Digital del Estado. Que tiene el objetivo de definir estándares mínimos de seguridad y ciberseguridad para todos los órganos de la administración pública en Chile, contribuyendo a la protección de los datos personales y a la seguridad de la información en los sistemas digitales gubernamentales.
- Resolución Exenta N° 342, de 9 de marzo del año 2018, del Ministerio de Salud,

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 7 de 36	TLP: BLANCO

por la que se aprueba el Programa Nacional de Telesalud.

- Circular N° 711 establece lineamientos sobre el uso de herramientas de inteligencia artificial (IA) en el sector público de Chile, proporcionando directrices para una implementación ética, segura y transparente de estas tecnologías en servicios gubernamentales. Con el objetivo de asegurar que las aplicaciones de IA en el sector público se alineen con los valores de protección de derechos, transparencia y seguridad de la información, además de fomentar la eficiencia y mejorar la calidad de los servicios público.

5 ROLES Y RESPONSABILIDADES.

• Responsable de Seguridad de la Información (CISO):

- Define, revisa la implementación de esta política. Supervisa los procesos de auditoría y cumplimiento.

• Unidad de Arquitectura:

- Es responsable de diseñar y definir los lineamientos técnicos, estándares y metodologías necesarias para garantizar una configuración coherente y segura de los entornos de nube. Esto incluye la selección de herramientas, tecnologías y enfoques específicos para la integración de servicios en la nube dentro de los modelos de almacenamiento existentes.
- Debe asegurar que las configuraciones elegidas cumplan con los requisitos de escalabilidad, interoperabilidad y cumplimiento normativo, optimizando tanto el rendimiento como la seguridad de los datos almacenados.

▪ Administradores de la nube (Accesos Privilegiados):

- Debe gestionar los accesos, la configuración y la seguridad de los entornos de nube, garantizando el cumplimiento de los estándares establecidos en esta política.
- Esta función abarca la administración de todos los entornos de nube asociados a las diferentes áreas o unidades de negocio que posean responsabilidad de gestión total por una contratación directa en base a sus requerimientos de servicios.

▪ Ingeniero Cloud:

- Responsable de la ejecución de acciones y configuraciones en los entornos de nube, siguiendo los diseños y lineamientos establecidos por la Unidad de Arquitectura.
- Debe implementar soluciones técnicamente sólidas que hayan sido previamente aprobadas por el CISO, asegurando que cumplan con los requisitos de seguridad, eficiencia y alineación estratégica definidos por la organización.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 8 de 36	TLP: BLANCO

▪ **Funcionarios Minsal (Usuarios):**

- Deben cumplir con las políticas de acceso, uso seguro de datos y notificar inmediatamente sobre cualquier incidente de seguridad.

▪ **Proveedor de la nube (AWS, Azure y GCP):**

- Debe cumplir con los acuerdos de nivel de servicio y permitir las auditorías para verificar la conformidad con los requisitos de seguridad.

6 MATERIAS QUE ABORDA.

- Arquitectura de Seguridad en la Nube AWS, GSP, Azure.
- Gestión de Identidades y Accesos (IAM)
- Protección de Datos
- Resiliencia y Continuidad
- Monitoreo y Detección de Amenazas
- Pruebas de Seguridad y Auditoría

7 DIRECTRICES DE LA POLÍTICA.

7.1 Arquitectura de seguridad basada en principios de seguridad.

Las medidas de control de acceso a la información definidas deben cumplir y ser consistentes con lo dispuesto por las normas legales y reglamentarias vigentes y cumplir con las demás condiciones previstas en la Política General de Seguridad de la Información y Ciberseguridad del Minsal:

- Diseñar la arquitectura de seguridad en la nube siguiendo los principios de confidencialidad, integridad, y disponibilidad (triada CIA) para proteger activos críticos.
- Incorporar los principios de seguridad desde la fase de diseño, que permita una configuración idónea en todos los entornos en la nube.
- Emplear prácticas de segmentación de red y aislamiento de cargas de trabajo, asegurando que las aplicaciones y datos estén protegidos contra accesos no autorizados.
- Resource Management (Gestión de Recursos): Implementar una gestión eficiente de recursos en la nube para optimizar su uso y protegerlos de amenazas. Esto incluye:
 - Control de asignación de recursos para evitar el aprovisionamiento excesivo y minimizar riesgos de exposición.
 - Monitoreo y administración continua de los recursos para detectar y mitigar los efectos de actividades sospechosas.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 9 de 36	TLP: BLANCO

- Políticas de uso eficiente de recursos para reducir costos y asegurar la disponibilidad constante de servicios críticos.
- Restricción de accesos y permisos a los recursos con base en el principio de mínimo privilegio.

7.1.1 Modelo de Confianza Zero

- Bajo el modelo Zero Trust, ninguna entidad ya sea usuario, dispositivo o aplicación es considerada confiable de manera predeterminada. Este principio asume que todas las comunicaciones entre los componentes de la arquitectura podrían representar una posible amenaza, por lo que toda interacción debe estar sujeta a autenticación, autorización y verificación continua antes de ser permitida.
- Toda comunicación en el sistema debe incluir autenticación multifactor (MFA) y autorización basada en el contexto, de modo que el acceso solo se otorgue a identidades verificadas y bajo circunstancias controladas.
- Es fundamental implementar segmentación de red para dividir el entorno en zonas de menor tamaño, minimizando los riesgos en caso de acceso no autorizado. La microsegmentación permite aislar datos críticos y aplicaciones, controlando que el acceso y tráfico en cada segmento, sólo sea el autorizado.

7.1.2 Seguridad desde el Diseño ("Security by Design").

- Incorporación de Controles de Seguridad desde la fase de diseño: La seguridad debe ser una parte integral del diseño de la arquitectura de nube desde el inicio. Esto implica aplicar medidas de protección en cada fase de desarrollo e implementación, asegurando que todos los componentes estén alineados con los estándares de seguridad establecidos por las normas ISO 27001, 27017 y 27018.
- Integración de Capas de Seguridad en todos los niveles: Las capas de seguridad deben implementarse en cada nivel de la arquitectura, desde el control de acceso hasta el almacenamiento y procesamiento de datos. Esto garantiza que las aplicaciones y los datos estén protegidos en todas las etapas del ciclo de vida del sistema y que la seguridad esté integrada en cada proceso.

7.1.3 Segmentación de Redes y Microsegmentación.

- División de Redes en Segmentos Más Pequeños: Las redes deben segmentarse en áreas más pequeñas para reducir la superficie de ataque y controlar mejor el acceso.
 - Se recomienda el uso de VLANs (Redes de Área Local Virtuales) para segmentar dentro de una misma infraestructura.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 10 de 36	TLP: BLANCO

- Control del Tráfico entre Segmentos: La microsegmentación implica aplicar políticas de control de tráfico estrictas entre los distintos segmentos de la red, asegurando que solo el tráfico autorizado tenga acceso a cada segmento. A estos efectos se recomienda usar herramientas tales como las siguientes:
 - Firewalls y/o WAF Perimetrales y de Aplicaciones que permita proteger cada segmento de red, mediante el monitoreo y restricción del tráfico entre segmentos. Estos son esenciales para asegurar que solo el tráfico necesario y validado pueda cruzar entre las distintas áreas de la red, reduciendo los riesgos de movimiento lateral en caso de brechas de seguridad.

7.2 Gestión de Identidad.

- Una gestión eficaz de identidades y accesos es crucial para proteger los recursos y datos sensibles en los entornos de nube de MINSAL. Esta capa de seguridad se enfoca en garantizar que cada usuario y servicio tenga acceso únicamente a los recursos necesarios para cumplir con sus tareas, aplicando principios de seguridad como el mínimo privilegio y autenticación multifactor (MFA).

7.2.1 Principio de Mínimo Privilegio.

- Restricción de Acceso al Mínimo Necesario: Se debe evitar que usuarios o servicios tengan privilegios excesivos que podrían ser explotados en caso de brecha de seguridad. Para ello, cada usuario, dispositivo o sistema debe contar únicamente con los permisos necesarios para acceder a los datos, recursos y aplicaciones que sean estrictamente necesarios para realizar sus tareas específicas, sin acceso adicional que pueda representar un riesgo.

7.2.2 Acceso Multi Factor MFA.

- Aplicación de MFA en Recursos Críticos: Para acceder a recursos y datos sensibles, todos los usuarios y administradores deben usar autenticación multifactor (MFA), que agrega una capa adicional de seguridad. MFA reduce significativamente el riesgo de acceso no autorizado al requerir un segundo factor de autenticación, como un código enviado a un dispositivo registrado.

7.2.3 Uso de Roles en lugar de Credenciales Estáticas.

- Eliminación de Credenciales Estáticas: Evitar el uso de credenciales o claves API permanentes que puedan quedar expuestas o comprometidas. En su lugar, se recomienda el uso de roles y permisos temporales que permitan la autenticación y

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 11 de 36	TLP: BLANCO

autorización seguras solo durante el tiempo necesario para ejecutar una tarea específica.

- Gestión de Acceso Temporal mediante Roles en AWS, Azure y GCP:
 - En AWS, los IAM Roles permiten asignar permisos temporales y específicos a usuarios y servicios, eliminando la necesidad de almacenar claves de acceso estáticas.
 - En Azure, las Managed Identities facilitan el acceso a servicios de Azure mediante credenciales automáticas y rotativas, eliminando la gestión manual de credenciales.
 - En GCP, se puede emplear el uso de Service Accounts con permisos específicos y temporales, diseñadas para aplicaciones y servicios que requieren acceso a otros recursos de Google Cloud.

7.3 Gestión de claves y el uso de técnicas de tokenización.

- La protección de datos es fundamental para garantizar que la información sensible de MINSAL esté segura en todo momento, tanto cuando está almacenada como cuando se transmite entre servicios y componentes de la arquitectura de nube. Esta capa de seguridad se enfoca en la implementación de cifrado robusto, una gestión centralizada y segura de claves criptográficas, y el uso de técnicas de tokenización y enmascaramiento para datos críticos.

7.3.1 Cifrado de Datos en Transito y en Reposo:

- Cifrado Obligatorio para Datos Sensibles: Todos los datos sensibles deben estar cifrados tanto en reposo (almacenamiento) como en tránsito (transmisión). Esto asegura que, incluso en el caso de una brecha de seguridad, los datos no puedan ser leídos sin las claves de descifrado correspondientes.

7.3.2 Gestión Segura de Claves (AWS KMS, Azure Key Vault, Google Cloud KMS):

- Centralización de la Gestión de Claves: La administración de claves criptográficas debe ser centralizada y segura, permitiendo un control adecuado sobre el acceso a los datos cifrados y facilitando la rotación y el monitoreo de las claves.
- Configuración de Rotación Automática y Control de Acceso:
 - En AWS, AWS KMS permite la rotación automática de claves y el registro detallado de todas las actividades relacionadas con el uso de las claves, mediante el control de acceso basado en IAM.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 12 de 36	TLP: BLANCO

- En Azure, Azure Key Vault permite establecer políticas de acceso y configuración de rotación automática de claves, con registros de auditoría que ayudan a monitorear el uso de las claves.
- En GCP, Google Cloud KMS proporciona controles avanzados de rotación y gestión de claves, junto con políticas de control de acceso que permiten restringir el uso de claves a servicios y usuarios específicos.

7.3.3 Tokenización y Enmascaramiento de Datos Sensibles.

- Protección Adicional para Datos Sensibles: Para asegurar la confidencialidad de información altamente sensible (como los datos de salud) o información confidencial, es recomendable el uso de técnicas de tokenización y enmascaramiento. Estas técnicas sustituyen los datos reales por identificadores o versiones enmascaradas, que no tienen valor fuera del sistema autorizado.

7.4 Geolocalización y Protección de Datos Sensibles.

7.4.1 Geolocalización y Protección de Datos Sensibles.

- La recopilación y uso de datos de geolocalización debe limitarse a lo estrictamente necesario para satisfacer las necesidades de información requeridas para el ejercicio de las competencias legales del organismo.
- Si los datos de geolocalización se almacenan o procesan fuera de Chile, MINSAL deberá garantizar que los proveedores de servicios en la nube cumplan con estándares aceptables de protección de datos personales. Esto incluye elegir proveedores ubicados en países con protección de datos equivalente o establecer contratos específicos que aseguren la integridad, confidencialidad y seguridad de los datos transferidos.
- Implementar medidas de seguridad para proteger los datos de geolocalización, incluyendo el cifrado en tránsito y en reposo, así como el uso de controles de acceso restringido.
- Los titulares de los datos de geolocalización tienen derecho a acceder, rectificar y solicitar la eliminación de su información, así como a revocar su consentimiento en cualquier momento. MINSAL deberá proporcionar procedimientos para que los titulares puedan ejercer estos derechos de manera efectiva.
- MINSAL debe llevar un registro detallado de todos los tratamientos, accesos y modificaciones de los datos de geolocalización, con el fin de asegurar la trazabilidad y verificar el cumplimiento de las normativas de protección de datos de Chile.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 13 de 36	TLP: BLANCO

- MINSAL debe realizar auditorías periódicas para verificar el cumplimiento de estas medidas, garantizando que solo el personal autorizado tenga acceso a los datos de geolocalización.

7.4.2 Diseño de Alta Disponibilidad y Recuperación ante Desastres.

- Uso de Múltiples Zonas de Disponibilidad (AZ) y Regiones: Implementar alta disponibilidad mediante el uso de múltiples zonas de disponibilidad (AZ) y regiones geográficas para reducir los puntos únicos de falla. Esto permite que, en caso de interrupciones en una zona o región, los servicios puedan seguir operando desde otra ubicación.
- Configuración de Estrategias de Failover en AWS, Azure y GCP:
 - En AWS, servicios como RDS Multi-AZ permiten la replicación de bases de datos en varias zonas de disponibilidad, con conmutación por error automática en caso de falla en la zona principal.
 - En Azure, se puede implementar alta disponibilidad mediante Azure SQL Database Failover Groups, que facilitan la conmutación entre bases de datos en diferentes regiones.
 - En GCP, el servicio de Google Cloud Spanner permite replicación global y recuperación de datos ante desastres, además de contar con estrategias de failover automático para otras bases de datos.
- Replicación de Aplicaciones y Bases de Datos: Asegurarse de que las aplicaciones críticas y bases de datos estén replicadas en tiempo real, listas para asumir la carga en caso de falla. La replicación debe probarse regularmente para garantizar que esté lista para una recuperación rápida en situaciones de emergencia.

7.4.3 Uso de Múltiples Zonas de Disponibilidad (AZ) y Regiones.

- Implementación de Redundancia Regional: Distribuir la infraestructura en varias zonas de disponibilidad y regiones para garantizar que los servicios críticos permanezcan operativos incluso en caso de interrupciones localizadas. Esta configuración ayuda a mitigar el impacto de incidentes como desastres naturales o fallos de hardware en una zona específica.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 14 de 36	TLP: BLANCO

7.4.4 Automatización de Failover y Backups Regulares.

- Automatización de Procesos de Recuperación: Automatizar la conmutación por error (failover) y la recuperación ante desastres mediante scripts y servicios gestionados, de modo que las aplicaciones y bases de datos puedan recuperarse rápidamente sin intervención manual. A estos efectos se deben implementar medidas como las siguientes:
 - Implementación de Backups Automáticos y Regulares: Asegurarse de que todos los datos críticos estén respaldados de forma automática y que estos backups se almacenen en ubicaciones seguras, con copias en diferentes regiones para una mayor protección.
 - Pruebas y Verificación de Restauración de Backups: Realizar pruebas periódicas de los backups y los procesos de restauración para asegurar que, en caso de desastre, los datos puedan recuperarse completamente y en el menor tiempo posible. Las pruebas de restauración permiten identificar y corregir posibles problemas en los procedimientos de recuperación antes de que ocurra una emergencia real.

7.4.5 Administración de la información de autenticación secreta de los usuarios (usuario y contraseña).

- El monitoreo y la detección de amenazas son esenciales para proteger los entornos de nube de MINSAL Chile contra ataques y actividades maliciosas. Esta capa de seguridad permite detectar las amenazas de manera temprana de forma tal que el equipo de seguridad pueda responder rápidamente para mitigar los posibles impactos. La implementación de herramientas de monitoreo, análisis de comportamiento y sistemas de respuesta automática contribuye a mantener la integridad y seguridad del entorno.

7.4.6 Uso de Herramientas SIEM (Security Information and Event Management):

- Implementación de Soluciones SIEM para Centralización y Correlación de Eventos: Las herramientas SIEM centralizan todos los registros de eventos de seguridad en un solo sistema, donde se analizan y correlacionan en tiempo real para detectar posibles amenazas. Al unificar los datos de seguridad de varias fuentes, las soluciones SIEM ayudan a identificar patrones anómalos y posibles incidentes de seguridad.

7.4.7 Análisis de Comportamiento de Usuarios y Entidades (UEBA):

- Implementación de Análisis Basado en Inteligencia Artificial: Las soluciones de análisis de comportamiento de usuarios y entidades (UEBA) utilizan inteligencia

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 15 de 36	TLP: BLANCO

artificial y aprendizaje automático para identificar patrones de comportamiento normal y detectar anomalías que puedan indicar un riesgo de seguridad. UEBA es especialmente útil para detectar amenazas internas y actividades que puedan pasar desapercibidas en otros sistemas de monitoreo.

7.4.8 Monitoreo Proactivo y Respuesta Automática a Eventos:

- **Detección Temprana de Amenazas y Respuestas Automatizadas:** Los sistemas de monitoreo proactivo permiten identificar amenazas en sus etapas iniciales y activar respuestas automáticas que reduzcan el impacto de posibles incidentes. La automatización de respuestas a través de políticas predefinidas minimiza el tiempo de reacción y protege el entorno de manera más eficaz.

7.4.9 Gestión de Vulnerabilidades y Actualización de Seguridad:

- **Evaluación y Remediación de Vulnerabilidades:**
 - Realizar evaluaciones periódicas de vulnerabilidades en sistemas, aplicaciones y redes para identificar riesgos potenciales.
 - Aplicar parches de seguridad y actualizaciones de manera oportuna para mitigar el riesgo de compromisos y minimizar la exposición a amenazas.
- **Automatización y Monitoreo:**
 - Implementar herramientas automatizadas de gestión de parches que permitan detectar, priorizar y aplicar actualizaciones de seguridad eficientemente.
 - Configurar alertas proactivas para abordar de manera inmediata las vulnerabilidades no gestionadas o críticas.
- **Ciclo de Revisión y Mejora Continua:**
 - Establecer un ciclo regular de revisión de seguridad que garantice la implementación de controles actualizados y alineados con las mejores prácticas de CIS (Center for Internet Security) y NIST (National Institute of Standards and Technology).
 - Documentar y auditar los procesos de gestión de vulnerabilidades para garantizar el cumplimiento normativo y mejorar la resiliencia de la infraestructura.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 16 de 36	TLP: BLANCO

7.4.10 Almacenamiento en Nube:

- **Reglas aplicables de acuerdo con la criticidad de la información:**
 - El almacenamiento en la nube está permitido únicamente para datos e información que sean necesarios para la operación y gestión de servicios, siempre que estos estén respaldados en plataformas autorizadas por el MINSAL.
 - Datos sensibles, como información de pacientes, registros clínicos o datos estratégicos, solo podrán ser almacenados en nube si el proveedor de servicios cumple con las normativas de seguridad vigentes.
 - Los datos clasificados como críticos solo podrán almacenarse en servicios que cuenten con configuraciones avanzadas de seguridad.
- **Proveedores Aprobados:**
 - Solo se permite el uso de servicios en la nube aprobados por el MINSAL, como AWS, Azure y GCP, con contratos vigentes que incluyan cláusulas de seguridad y cumplimiento normativo.
 - No se permite el uso de servicios de almacenamiento personales (Google Drive, Dropbox personal, etc.) para actividades relacionadas con el MINSAL.
- **Límites de Acceso y Compartición:**
 - El acceso a la información almacenada en la nube estará limitado únicamente al personal autorizado.
 - La comunicación y la compartición de datos y documentos deberá realizarse mediante métodos seguros que limiten la exposición de datos a usuarios no autorizados.
- **Reglas y Criterios para el Uso Seguro:**
 - **Cifrado de Datos:**
 - ✓ Todos los datos almacenados en la nube deben ser cifrados tanto en tránsito como en reposo, utilizando estándares reconocidos como AES-256.
 - ✓ Las claves de cifrado deben gestionarse de manera segura y restringida a usuarios con roles específicos.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 17 de 36	TLP: BLANCO

- **Gestión de Identidad y Acceso:**
 - ✓ Se debe usar autenticación multifactor (MFA) para acceder a los servicios en la nube.
 - ✓ Configurar permisos basados en roles (RBAC) para garantizar que los empleados accedan únicamente a los datos necesarios para sus funciones.
- **Clasificación de Información:**
 - ✓ Antes de almacenar información en la nube, esta debe clasificarse según las políticas internas del MINSAL (ej.: confidencial, sensible o pública).
 - ✓ Para cada categoría se deben evaluar y gestionar los riesgos de acuerdo con el modelo tecnológico proyectado.
- **Procedimientos de Backup y Recuperación:**
 - ✓ Implementar copias de seguridad automáticas para los datos almacenados en la nube y replicarlas en múltiples regiones para garantizar su disponibilidad.
 - ✓ Realizar pruebas regulares de restauración para verificar la integridad de los datos respaldados.
- **Procedimientos Obligatorios para funcionarios:**
 - **Cumplimiento de Políticas:**
 - ✓ Los empleados deben seguir estrictamente las políticas del MINSAL relacionadas con el almacenamiento en la nube, evitando el uso de dispositivos o cuentas personales para acceder o gestionar información sensible.
 - **Capacitación Regular:**
 - ✓ Todo el personal autorizado para usar servicios en la nube debe participar en capacitaciones periódicas sobre buenas prácticas de seguridad y gestión de datos en entornos de nube.
 - **Reportes de Incidentes:**

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 18 de 36	TLP: BLANCO

- ✓ Cualquier incidente relacionado con el uso de almacenamiento en la nube, como accesos no autorizados o pérdida de datos, debe ser reportado de inmediato al área de TI o al Encargado de Seguridad de la Información/ Ciberseguridad.

7.5 Pruebas de Seguridad y Auditoría.

- Las pruebas de seguridad y auditoría son esenciales para identificar y remediar vulnerabilidades en la infraestructura de nube de MINSAL. Este apartado abarca prácticas de seguridad avanzadas, como pruebas de penetración, simulación de ataques y revisiones periódicas de la arquitectura, que permiten evaluar y optimizar continuamente la postura de seguridad en entornos de nube pública.

7.5.1 Pruebas de Penetración y Auditorías de Terceros.

- Pruebas de Penetración Periódicas:** Las pruebas de penetración permiten identificar vulnerabilidades en la infraestructura de nube mediante la simulación de ataques que evalúan la resistencia de los sistemas y aplicaciones frente a posibles intrusiones. Es importante realizarlas de manera periódica para descubrir y mitigar amenazas antes de que puedan ser explotadas.
- Contratación de Auditorías Externas:** Las auditorías externas, realizadas por organizaciones independientes, permiten validar la conformidad de los entornos de nube con estándares de seguridad como ISO 27001, 27017 y 27018. Estas auditorías ayudan a asegurar que se cumplan las normativas y se apliquen las mejores prácticas de seguridad.

7.5.2 Metodología de simulación de Red Team y Ethical Hacking:

Las metodologías para la simulación de Red Team y Ethical Hacking deben ser definidas y aprobadas por MINSAL, en conjunto con las áreas de Ciberseguridad y Arquitectura. Estas metodologías tienen como propósito fortalecer la inteligencia de amenazas mediante ejercicios avanzados de ciberseguridad, tales como análisis de vulnerabilidades, pruebas de penetración (Pentest), Ethical Hacking y simulaciones de ataques reales. Los equipos de Red Teaming son responsables de identificar puntos débiles en la seguridad, utilizando técnicas avanzadas para descubrir fallos que podrían pasar desapercibidos en pruebas tradicionales.

- Objetivos del Red Teaming:** Los equipos de Red Teaming buscan desafiar los sistemas de defensa, exponiendo vulnerabilidades de manera proactiva para mejorar continuamente la postura de seguridad de la organización. Estas simulaciones

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 19 de 36	TLP: BLANCO

permiten evaluar la efectividad de los controles de seguridad, identificar brechas en la protección y entrenar al equipo de respuesta ante incidentes.

- **Frecuencia y Gestión:** La organización debe realizar ejercicios de Red Teaming, Pentest o Ethical Hacking al menos una vez al año. Además, el análisis de vulnerabilidades debe llevarse a cabo en un intervalo no mayor a tres meses, garantizando una gestión proactiva de riesgos. Este enfoque integral asegura una retroalimentación constante que permite ajustar estrategias y fortalecer los controles de seguridad en tiempo real.

7.5.3 Revisiones de Arquitectura de Seguridad.

- **Revisiones Periódicas de la Arquitectura de Seguridad:** Es esencial realizar revisiones periódicas de la arquitectura de seguridad en la nube para identificar y corregir posibles debilidades en los controles de seguridad y optimizar la configuración en función de nuevas amenazas y vulnerabilidades.
- **Optimización Basada en Recomendaciones de Seguridad:** Las herramientas de asesoría de seguridad en la nube, como AWS Trusted Advisor y Azure Advisor, proporcionan recomendaciones sobre mejores prácticas y optimización de seguridad. Estas recomendaciones ayudan a los administradores a ajustar la configuración de los recursos en función de las últimas amenazas y cambios en el entorno.

7.6 Almacenamiento en Nube:

- Establecer en qué casos se permite utilizar el almacenamiento en la nube y mantener de modo seguro la información almacenada en esta modalidad, especificando reglas, criterios y procedimientos que deben seguir todos los empleados que usen estos servicios.

7.6.1 Uso de servicios de almacenamiento en nubes públicas.

- **Criterios de uso:**
 - Las nubes públicas podrán utilizarse exclusivamente para almacenar información no crítica ni confidencial, como reportes estadísticos no sensibles o documentación administrativa de soporte.
 - Está estrictamente prohibido almacenar datos personales, confidenciales o sensibles en nubes públicas no autorizadas.
- **Proveedores aprobados:**

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 20 de 36	TLP: BLANCO

- Solo están permitidos los siguientes proveedores de nubes públicas, siempre que cumplan con las políticas internas de seguridad:
 - AWS (Amazon Web Services): Servicios como S3, RDS y Glacier.
 - Microsoft Azure: Servicios como Azure Blob Storage y Azure Files.
 - Google Cloud Platform (GCP): Servicios como Google Cloud Storage y Filestore.

▪ **Restricciones:**

- Queda prohibido el uso de servicios de almacenamiento no corporativos como Dropbox, Google Drive personal y plataformas similares no gestionadas por el área de TI.

▪ **Acceso desde dispositivos seguros:**

- Solo se permite el acceso a los servicios de almacenamiento en nubes públicas desde dispositivos gestionados por el área de TI y con controles de seguridad actualizados.

▪ **Revisión periódica de proveedores:**

- Los proveedores aprobados deben ser evaluados anualmente para verificar su conformidad con los estándares de seguridad y normativas vigentes.

7.6.2 Lista de servicios de almacenamiento en la nube permitidos

▪ **Proveedores aprobados por el MINSAL:**

○ **Amazon Web Services (AWS):**

- Servicios permitidos: S3, RDS, Glacier.
- Uso permitido: Datos operativos y bases de datos sensibles bajo configuraciones avanzadas de seguridad.

○ **Microsoft Azure:**

- Servicios permitidos: Azure Blob Storage, Azure Files.
- Uso permitido: Datos operativos y bases de datos sensibles bajo configuraciones avanzadas de seguridad.

○ **Google Cloud Platform (GCP):**

- Servicios permitidos: Google Cloud Storage, Filestore.
- Uso permitido: Datos operativos y bases de datos sensibles bajo configuraciones avanzadas de seguridad.

▪ **Restricciones:**

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 21 de 36	TLP: BLANCO

- Están **prohibidos** los servicios no gestionados por el área de TI, como Dropbox, Google Drive personal y cualquier otra plataforma de uso no corporativo.

7.6.3 Proceso de eliminación de información:

▪ Definición de políticas de retención:

- Toda información almacenada en la nube debe contar con políticas claras de retención. Los datos deben eliminarse cuando ya no sean necesarios para operaciones relacionadas con la gestión del ciclo de vida de la información del Minsal alojada en la nube o de acuerdo con el cumplimiento normativo.

▪ Métodos de eliminación segura:

- Utilizar herramientas nativas de los proveedores para garantizar el borrado seguro, como AWS S3 Object Lock o el borrado criptográfico en Azure y GCP.
- Confirmar la eliminación total mediante auditorías y reportes automáticos.

▪ Registro de eliminación:

- Documentar cada proceso de eliminación, incluyendo:
 - Fecha y hora de la eliminación.
 - Usuario responsable.
 - Confirmación de la eliminación exitosa.

7.6.4 Copias de seguridad en la nube

▪ Automatización de respaldos:

- Todos los sistemas críticos deben contar con copias de seguridad automatizadas en la nube para garantizar su disponibilidad en caso de fallas o desastres.

▪ Distribución de copias:

- Las copias de seguridad deben almacenarse en:
 - Múltiples regiones para proteger contra desastres regionales.
 - ✓ Las copias de seguridad deben ser almacenadas exclusivamente en nubes públicas con infraestructura ubicada dentro del territorio de Chile, con el fin de asegurar la resiliencia y la continuidad del servicio ante cualquier desastre o incidente, y para garantizar el cumplimiento de las leyes sobre protección de datos y ciberseguridad aplicables en el país.
 - ✓ En caso de que el proveedor de la nube pública no cuente con infraestructura en Chile, se deberá implementar una política de no

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 22 de 36	TLP: BLANCO

replicación fuera de Chile o, al menos, controlar estrictamente la replicación de datos hacia centros de datos ubicados en otros países.

- ✓ Si se utilizan plataformas de nube pública como AWS, Azure o Google Cloud, se deberá garantizar que las copias de seguridad se almacenen en múltiples regiones dentro del país. En caso de que solo exista una región disponible, se permitirá el uso de zonas de disponibilidad separadas dentro de la misma infraestructura para asegurar la redundancia y disponibilidad de los datos.
- ✓ Se recomienda implementar un enfoque híbrido para el almacenamiento de copias de seguridad, donde la copia primaria se almacene en infraestructura propia (ya sea local o en un servicio de nube privada) y la copia secundaria en nube pública. Este enfoque asegura redundancia y proporciona un control robusto sobre la información crítica para el Minsal, garantizando la disponibilidad y seguridad de los datos en todo momento.

- Servicios con alta disponibilidad, como AWS Glacier o Azure Backup.

▪ **Pruebas de restauración:**

- Realizar pruebas regulares para verificar que los datos respaldados puedan restaurarse con éxito.
- Documentar los resultados de las pruebas e implementar mejoras en caso de fallas en los procesos de restauración.

▪ **Cifrado de respaldos:**

- Todas las copias de seguridad deben estar cifradas tanto en reposo como en tránsito utilizando algoritmos de cifrado reconocidos (ej. AES-256). Las claves de cifrado deben gestionarse de forma segura.
- El acceso a las copias de seguridad debe estar estrictamente controlado mediante políticas de autenticación multifactorial (MFA)

7.6.5 Auditoría y Supervisión Post-Contratación.

- Implementar auditorías periódicas para asegurar que el proveedor cumpla con las condiciones establecidas en el contrato, incluyendo seguridad y tiempo de actividad.
- Establecer un canal directo con el proveedor para reportar y resolver incidentes de seguridad o interrupciones de servicio.
- Evaluar anualmente la calidad del servicio y la conformidad del proveedor con las normativas aplicables. Renovar el contrato únicamente si cumple con los estándares exigidos por el MINSAL.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 23 de 36	TLP: BLANCO

7.7 Contratación de servicios en Nube:

- La contratación de servicios en la nube por parte del MINSAL debe alinearse con el *Manual de Recomendaciones Técnicas para la Adquisición de Servicios de Cloud Pública en los Órganos de la Administración del Estado de Chile*, garantizando una adquisición eficiente, segura y ajustada a las necesidades del sector público².

- **Criterios Generales para la Contratación:**

- **Análisis Previo:**

Determinar la necesidad del servicio para cumplir con los objetivos estratégicos del MINSAL.

Realizar un estudio de alternativas disponibles en el mercado y llevar a cabo una evaluación comparativa.

- **Evaluación de Propuestas:**

- Analizar propuestas de proveedores según criterios de:
 - ✓ Seguridad: Cumplimiento de normativas y estándares internacionales.
 - ✓ Costos: Modelos de precios claros y competitivos. Previsibilidad y transparencia en la fijación de precios por los servicios.
 - ✓ Disponibilidad y Escalabilidad: Recursos ajustables a demanda.

- **Revisión Legal y Técnica:**

- Garantizar que los contratos incluyan:
 - ✓ Protección de datos personales.
 - ✓ Mecanismos de resolución de disputas ajustadas a la normativa nacional.

² <https://digital.gob.cl/transformacion-digital/estandares-y-guias/manual-de-recomendaciones-tecnicas-para-la-adquisicion-de-servicios-de-cloud-publica-en-los-organos-de-la-administracion-del-estado/>

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 24 de 36	TLP: BLANCO

✓ Cláusulas de finalización: retorno o eliminación segura de los datos.

▪ **Formalización y Supervisión:**

- Formalizar el contrato con el proveedor seleccionado.
- Establecer sistemas de monitoreo continuo para garantizar el cumplimiento de condiciones.

▪ **Supervisión y Auditoría de Servicios Nube.**

○ **Monitoreo Continuo:**

- Implementar herramientas para supervisar el desempeño del proveedor y el cumplimiento de los SLA (Service Level Agreements).

○ **Auditorías Periódicas.**

- Realizar auditorías anuales para verificar la conformidad del servicio con las políticas del MINSAL y los estándares internacionales de seguridad.

○ **Gestión de Incidentes.**

- Establecer un protocolo para reportar, investigar y resolver incidentes relacionados con los servicios contratados.

○ **Definición de Requerimientos Técnicos.**

- **Especificaciones del Servicio:** Identificar necesidades específicas, como:

- ✓ Capacidad de almacenamiento y procesamiento.
- ✓ Seguridad de la información.
- ✓ Cumplimiento normativo y regulaciones locales.

○ **Alineación con el Marco EvalTIC (de acuerdo con la normativa vigente):**

Formular los proyectos de adquisición de servicios en la nube en el marco del proceso EvalTIC, asegurando que se justifiquen técnica y financieramente. El cual define lo siguiente:

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 25 de 36	TLP: BLANCO

- **Evaluación Estratégica:** Diseñar un plan detallado que incluya evaluación de necesidades, planificación, y definición de un modelo de operación para servicios en la nube.
 - **Modelo Financiero:** Basado en OPEX (operación), facilita flexibilidad presupuestaria en lugar de inversiones en infraestructura (CAPEX).
 - **Seguridad y Cumplimiento:** Requiere que los servicios cumplan con estándares internacionales de seguridad (ISO 27001, 27017, 27018) y normativas chilenas.
 - **Capacidades Internas:** Se exige contar con profesionales capacitados en gestión de servicios en la nube antes de realizar adquisiciones.
 - **Criterios para Contratación:** Territorialidad: La normativa chilena no obliga a mantener datos dentro del territorio nacional, salvo disposiciones sectoriales.
 - **Decisiones Técnicas:** La modalidad SaaS es preferida para software estándar, mientras que IaaS y PaaS requieren capacidades técnicas avanzadas.
 - **SLAs (Acuerdos de Nivel de Servicio):** Deben incluir tiempo de actividad (uptime), rendimiento, tiempo de respuesta, seguridad, y compensaciones claras por incumplimientos. Es crucial personalizar y revisar periódicamente los SLAs según las necesidades del organismo.
 - **Elección del Proveedor:** Basada en fiabilidad, seguridad, escalabilidad, rendimiento, y soporte técnico. Se debe considerar la proximidad de los centros de datos y la capacidad del proveedor para ofrecer soluciones específicas.
 - **Gestión y Seguimiento:** Implementar herramientas de monitoreo en tiempo real, revisiones periódicas de SLA, y auditorías para asegurar el cumplimiento del proveedor. Establecer equipos especializados para la gestión proactiva de problemas e incidentes.
- **Compatibilidad con el Marco Legal y Normativo:**
 - Verificar que el proveedor cumpla con las regulaciones chilenas, especialmente en lo relacionado con la Ley de Protección de Datos Personales y las directrices de seguridad aplicables al sector público.
 - **Certificaciones Internacionales:**
 - Exigir certificaciones, los servicios en la nube contratados deben estar respaldados por certificaciones como ISO/IEC 27001, ISO/IEC 27017 e ISO/IEC 27018 o equivalentes para garantizar la seguridad y protección de los datos personales.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 26 de 36	TLP: BLANCO

○ **Requisitos Específicos para Proveedores de Nube:**

▪ **Ubicación de los Datos:**

- ✓ Priorizar el almacenamiento de datos en regiones que garanticen su protección bajo estándares internacionales y que cumplan con las normativas de protección de datos personales vigentes en Chile durante todo el tiempo previsto para el servicio.

▪ **Modelo de Responsabilidad Compartida:**

- ✓ Garantizar que el proveedor detalle claramente las responsabilidades que asume en la seguridad física, lógica y en la gestión de datos.

▪ **SLA (Acuerdo de Nivel de Servicio):**

- ✓ Establecer contratos que incluyan:
 - Disponibilidad mínima del servicio del 99.9%.
 - Tiempos de respuesta y resolución para incidentes críticos en un plazo máximo de 4 horas.
 - Compromisos explícitos sobre la seguridad y confidencialidad de los datos.

▪ **Evaluación de Riesgos:**

- ✓ Antes de la contratación, realizar una evaluación de riesgos para identificar posibles vulnerabilidades asociadas al proveedor y al servicio.

7.7.1 Medidas organizativas.

▪ **Uso No Autorizado.**

- Para garantizar el uso adecuado, seguro y conforme a las normativas de los servicios en la nube contratados por el MINSAL, se establecen las siguientes medidas organizativas:

▪ **Acceso restringido.**

- Queda prohibido utilizar servicios de almacenamiento en la nube o cualquier servicio de nube pública que no haya sido previamente autorizado por el área de TI o el comité de ciberseguridad del MINSAL.
- Se prohíbe explícitamente el uso de plataformas de almacenamiento personal (como Dropbox, Google Drive personal u otras similares) para gestionar datos o procesos relacionados con las operaciones del MINSAL.
- Los empleados solo podrán acceder y utilizar los servicios en la nube a través de dispositivos corporativos y redes aprobadas por el área de TI.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 27 de 36	TLP: BLANCO

- **Auditabilidad.**
- **Registro de Actividades.**
 - Todos los servicios en la nube contratados deben garantizar la capacidad de auditar actividades realizadas, incluyendo:
 - Accesos, modificaciones y eliminaciones de datos.
 - Movimientos entre regiones de almacenamiento.
 - Los registros de auditoría deben mantenerse disponibles por un período mínimo de 5 años y ser accesibles para inspecciones internas o regulatorias.
- **Herramientas de Auditoría.**
 - Implementar herramientas automáticas para supervisar las actividades en la nube y generar reportes periódicos sobre el uso del servicio.

Notificación de incidentes de seguridad de la información o ciberseguridad.

- **Notificación de Incidentes.**
 - Los proveedores de servicios en la nube están obligados a:
 - ✓ Notificar al Oficial de Seguridad de la Información de MINSAL sobre cualquier incidente de seguridad que afecte la confidencialidad, integridad o disponibilidad de los datos en un plazo máximo de 3 horas.
 - ✓ Resguardar evidencias iniciando cadena de custodia.
 - ✓ Proveer detalles del incidente, las medidas adoptadas y los planes de mitigación.
 - Los funcionarios deben reportar inmediatamente cualquier anomalía o incidente relacionado con los servicios en la nube al equipo de TI o al CISO (Chief Information Security Officer) del MINSAL.
 - Los incidentes deberán reportarse en el portal de la ANCI, conforme al Reglamento de Reporte de Incidentes de Ciberseguridad (Decreto N° 295/2024).
 - Los Proveedores de Servicios Esenciales deberán cumplir estrictamente con las obligaciones establecidas en el Artículo 5° de la Ley N° 21.663 y su reglamento, incluyendo la implementación de medidas de mitigación y la cooperación con la Agencia Nacional de Ciberseguridad (ANCI) en la gestión y resolución de incidente.

7.7.2 Medidas técnicas.

- El MINSAL debe implementar medidas técnicas robustas para garantizar la seguridad y disponibilidad de los servicios en la nube, alineándose con los estándares internacionales y mejores prácticas. Las medidas incluyen

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 28 de 36	TLP: BLANCO

certificaciones de seguridad, protección de datos mediante encriptación y seudonimización, y la elasticidad de los recursos tecnológicos.

Certificaciones de seguridad.

▪ **Requisito de Certificación:**

- Los proveedores de servicios en la nube contratados deben estar certificados bajo estándares internacionales reconocidos, como:
 - ✓ ISO/IEC 27001: Gestión de la seguridad de la información.
 - ✓ ISO/IEC 27017: Controles de seguridad específicos para servicios en la nube.
 - ✓ ISO/IEC 27018: Protección de datos personales en servicios en la nube.

▪ **Cumplimiento de Normativas Locales:**

- Los servicios deben cumplir con las regulaciones nacionales, como la Ley de Protección de Datos Personales, asegurando que la información almacenada sea tratada conforme a las disposiciones legales chilenas.

▪ **Supervisión Continua:**

- Verificar periódicamente que los proveedores mantengan sus certificaciones vigentes y cumplan con los estándares establecidos durante toda la vigencia del contrato.

Encriptación de datos.

▪ **Cifrado en Reposo y en Tránsito:**

- Toda la información almacenada en la nube debe estar cifrada utilizando estándares robustos, como AES-256.
- Los datos en tránsito entre el cliente y el servicio de nube deben protegerse mediante protocolos seguros como TLS 1.3.

▪ **Gestión de Claves de Cifrado:**

- Las claves criptográficas deben ser generadas, gestionadas y almacenadas en sistemas seguros, como módulos de seguridad de hardware (HSM).
- Preferir la administración de claves bajo control exclusivo del MINSAL, utilizando herramientas como AWS Key Management Service (KMS) o Azure Key Vault.

▪ **Protección Contra Accesos No Autorizados:**

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 29 de 36	TLP: BLANCO

- Implementar autenticación multifactor (MFA) para acceder a las claves y a los sistemas donde se almacenen datos cifrados.

Seudonimización.

■ Protección de Identidades:

- Antes de almacenar datos personales sensibles en la nube, estos deben ser seudonimizados, reemplazando elementos identificables por pseudónimos únicos que no permitan identificar directamente al individuo.

■ Técnicas de Seudonimización:

- Utilizar métodos como:
 - ✓ Tokenización: Sustitución de datos sensibles por un identificador único.
 - ✓ Hashing: Aplicación de algoritmos criptográficos para anonimizar datos.
- Garantizar que las claves para revertir la seudonimización se gestionen en sistemas separados y seguros.

■ Cumplimiento de Normativas:

- La seudonimización debe cumplir con los principios establecidos por la Ley de Protección de Datos Personales y los estándares internacionales aplicables.

■ Elasticidad.

■ Capacidad de Escalamiento Automático:

- Los servicios en la nube deben ofrecer elasticidad, permitiendo aumentar o reducir automáticamente los recursos según las necesidades del MINSAL.
- Usar herramientas como:
 - ✓ AWS Auto Scaling: Para ajustar la capacidad de instancias según la demanda.
 - ✓ Azure Autoscale: Para balancear recursos en tiempo real.
 - ✓ Google Cloud Autoscaler: Para garantizar disponibilidad y minimizar costos.

■ Garantía de Disponibilidad:

- Configurar sistemas para operar bajo esquemas de alta disponibilidad (HA), distribuyendo recursos en múltiples regiones o zonas de disponibilidad.

■ Optimización de Recursos:

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 30 de 36	TLP: BLANCO

- Implementar políticas para liberar automáticamente recursos no utilizados, reduciendo costos y mejorando la eficiencia operativa.
- **Pruebas de Carga y Resiliencia:**
 - Realizar pruebas periódicas para verificar que el sistema pueda manejar aumentos repentinos en la carga y mantener la estabilidad operativa.
- **Monitoreo y Cumplimiento:**
 - **Supervisión Continua:**
 - ✓ Implementar mecanismos de monitoreo continuo para garantizar que los proveedores cumplan con los Acuerdos de Nivel de Servicio (SLA) y las políticas internas del MINSAL.
 - **Indicadores de Cumplimiento:** Definir KPIs (Indicadores Clave de Desempeño) para evaluar el cumplimiento de los proveedores, como:
 - ✓ Tasa de disponibilidad del servicio.
 - ✓ Tiempo promedio de resolución de incidentes.
 - ✓ Conformidad con las auditorías de seguridad.
 - **Revisión Periódica:**
 - ✓ Realizar revisiones trimestrales o semestrales del desempeño de los servicios en la nube para garantizar que cumplan con las expectativas y necesidades del MINSAL.
- **Condiciones contractuales.**
 - **Protección de Datos:**
 - Los contratos deben incluir cláusulas específicas para garantizar:
 - ✓ El cumplimiento de las normativas locales e internacionales de protección de datos (ISO/IEC 27001, 27017 y 27018).
 - ✓ La propiedad exclusiva de los datos por parte del MINSAL.
 - Devolución y Eliminación de Datos:
 - ✓ Establecer condiciones claras para la devolución y eliminación segura de los datos al término del contrato, garantizando que no queden copias residuales en los sistemas del proveedor.
 - Responsabilidad Legal:
 - ✓ Incluir cláusulas que especifiquen la responsabilidad del proveedor en caso de pérdida, alteración o filtración de datos.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 31 de 36	TLP: BLANCO

- Acuerdos de Nivel de Servicio (SLA) que prevean detalladamente las exigencias y métricas de cumplimiento:
 - ✓ Disponibilidad mínima del 99.98% del servicio.
 - ✓ Tiempo máximo de respuesta para incidentes críticos: 4 horas.
 - ✓ Soporte técnico 24/7.
 - ✓ Detalle de métricas específicas para medir el desempeño del servicio, como latencia, tiempo de respuesta y tiempo de recuperación.
- Sanciones: En caso de incumplimiento de los SLA, los contratos deben incluir sanciones financieras o de otro tipo, tales como:
 - ✓ Penalidades económicas proporcionales al impacto del incumplimiento.
 - ✓ Rescisión anticipada del contrato sin costos adicionales para el MINSAL.
 - ✓ Compromisos de Mitigación: Si se produce un incidente o falla, el proveedor debe implementar de inmediato un plan de acción correctiva para mitigar los daños y prevenir futuras ocurrencias.

7.7.3 Resguardos de legalidad de las cláusulas:

- Los contratos no deberán considerar cláusulas que estén fuera de las competencias del Ministerio, a saber:
 - ✓ Prórroga de competencia a tribunales extranjeros o tribunales arbitrales.
 - ✓ Renuncia a las responsabilidades del proveedor.
 - ✓ Renuncia a las garantías.
 - ✓ Aceptación de cláusulas que representen cesiones de datos sensibles o datos personales en hipótesis no autorizadas por la ley.

8 PROPIEDAD INTELECTUAL EN ENTORNOS CLOUD:

Todas las actividades realizadas en la nube pública deberán cumplir con las leyes y normativas aplicables sobre propiedad intelectual y propiedad industrial, incluyendo las relacionadas con patentes, derechos de autor, marcas y secretos comerciales, debiendo adoptarse a lo menos las siguientes medidas:

- Toda la propiedad intelectual generada, creada o desarrollada durante la ejecución de actividades en entornos de nube pública será propiedad exclusiva del Minsal. Esto incluye, pero no se limita a, software, código fuente, algoritmos, documentos, diseños, bases de datos, y cualquier otro material o activo que derive de las actividades realizadas en estos entornos.
- El acceso a las obras protegidas por propiedad intelectual será restringido a las personas autorizadas y se revisará periódicamente para garantizar que solo los empleados y colaboradores necesarios tengan acceso a los recursos relevantes.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 32 de 36	TLP: BLANCO

- Minsal implementará las medidas de seguridad necesarias para proteger el material protegido por propiedad intelectual en los entornos de nube pública, incluyendo el uso de encriptación, controles de acceso y autenticación, y monitoreo continuo.
- En la relación con proveedores, se adoptarán a lo menos los siguientes resguardos:
 - ✓ Los proveedores de servicios en la nube pública (incluidos los servicios de almacenamiento, procesamiento y desarrollo) no obtendrán derechos sobre las obras protegidas por propiedad intelectual de Minsal en virtud de la utilización de dichos servicios.
 - ✓ Los proveedores solo tendrán derecho a usar el material protegido bajo las condiciones específicas acordadas en los contratos de servicio, y únicamente en la medida necesaria para la prestación de sus servicios.

9 MECANISMO DE DIFUSIÓN:

- La comunicación de la presente política se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:
 - Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
 - Correo informativo.
 - Publicación en el sitio web de Minsal http://www.minsal.cl/seguridad_de_la_informacion/

10 PERÍODO DE REVISIÓN:

- El presente procedimiento deberá ser revisado cada dos años o cuando ocurran cambios significativos para garantizar que:
 - Sigue siendo adecuado para su propósito y preciso.
 - Refleja los cambios en las tecnologías.
 - Está alineado con la legislación vigente, los estándares internacionales y las mejores prácticas.

11 EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA:

En situaciones excepcionales, el Jefe de TIC, el CISO o el Comité de Seguridad de la Información tendrán la facultad de evaluar y establecer condiciones específicas para la excepción al cumplimiento de las directrices establecidas en esta política, siempre que tales excepciones no infrinjan la legislación vigente ni comprometan la seguridad de la información.

Cada excepción deberá ser debidamente documentada, y se deberá iniciar un proceso de revisión de la política en el que se determinará si es necesario incorporar

directrices adicionales o realizar modificaciones específicas.

12 HISTORIAL Y CONTROL DE VERSIONES:

Versión	Fecha	Pág. o Sección modificada	Motivo del cambio
01	Diciembre 2024	Todas	Creación del documento

13 ANEXO Cloud Security Comparison: AWS vs Azure vs GCP:

Configuración de redes aisladas según el proveedor nube		
AWS	GCP	AZURE
Usar Virtual Private Cloud (VPC) para establecer zonas de red separadas y seguras.	Implementar Virtual Private Cloud (VPC) con subredes, definiendo áreas con distintos niveles de acceso y aplicando controles de seguridad específicos en cada región.	Utilizar Virtual Network (VNet) para aislar y gestionar recursos y aplicaciones.
Control de Tráfico entre segmentos		
AWS	GCP	AZURE
Security Groups, Network Access Control Lists (NACLs) en AWS.	Google Cloud Firewalls en GCP, que permiten definir reglas de entrada y salida para controlar qué tráfico puede acceder a cada instancia o subred en la VPC de GCP.	Network Security Groups (NSG) en Azure.
Principio de Mínimo Privilegio: Configuración de políticas IAM		
AWS	GCP	AZURE
Las políticas de Identity and Access Management (IAM) permiten definir permisos específicos para cada rol o usuario, garantizando que solo los recursos necesarios estén accesibles.	En GCP, se implementa IAM de Google Cloud para asignar permisos mínimos necesarios, con roles personalizados que se adaptan a las necesidades específicas de cada usuario o servicio.	En Azure, Azure Active Directory (AD) y las políticas de rol de Role-Based Access Control (RBAC) permiten configurar permisos detallados para usuarios y grupos.
Implementación de MFA		
AWS	GCP	AZURE
El uso de MFA en IAM se puede configurar para cada usuario y rol, con opciones para dispositivos físicos o aplicaciones de autenticación	Se recomienda habilitar MFA en las cuentas de usuario de Google Cloud Identity, añadiendo así una capa extra de protección para todas las identidades que interactúan	Azure AD MFA permite habilitar MFA en cuentas de usuario y aplicaciones críticas, aplicando políticas de acceso condicional para situaciones de riesgo.

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 34 de 36	TLP: BLANCO

con recursos críticos.		
Implementación de uso de múltiples zonas de disponibilidad		
AWS	GCP	AZURE
Distribuir aplicaciones en múltiples Availability Zones dentro de una misma región y, si es necesario, en varias regiones geográficas.	Implementar el despliegue en múltiples regiones y zonas, aprovechando la red global de Google para reducir la latencia y asegurar la continuidad del servicio.	Utilizar Availability Zones y Paired Regions (regiones emparejadas) para asegurar redundancia regional.
Automatización Failover		
AWS	GCP	AZURE
AWS Lambda para ejecutar scripts de failover y recuperación automática.	Google Cloud Functions en GCP para ejecutar scripts de failover en caso de fallos.	Azure Automation para automatizar flujos de trabajo de recuperación ante desastres y conmutación por error.
Implementación de backup automáticos y regulares		
AWS	GCP	AZURE
En AWS, los backups automáticos de servicios como RDS y S3 permiten almacenar copias de seguridad de manera regular y segura.	En GCP, Google Cloud Backup and Disaster Recovery permite la programación de backups automáticos y el almacenamiento en múltiples ubicaciones.	En Azure, Azure Backup y Azure Site Recovery ofrecen soluciones de copia de seguridad automatizada y recuperación ante desastres, con verificación periódica de los datos.
Uso de herramientas SIEM		
AWS	GCP	AZURE
En AWS, Amazon GuardDuty proporciona capacidades de monitoreo y detección de amenazas basadas en SIEM, con alertas automáticas para actividades sospechosas.	En GCP, Chronicle es la solución de seguridad nativa de Google que ofrece monitoreo centralizado y correlación de eventos para identificar amenazas de seguridad de manera oportuna.	En Azure, Microsoft Sentinel es una solución SIEM y SOAR (Security Orchestration, Automation, and Response) que permite recopilar, analizar y actuar sobre eventos de seguridad en tiempo real, con capacidades avanzadas de automatización.
Análisis de comportamiento		
AWS	GCP	AZURE
En AWS, Amazon GuardDuty usa análisis de comportamiento para detectar actividades inusuales en el entorno de AWS, como accesos no autorizados o movimientos laterales en la red.	En GCP, Cloud Security Command Center (Cloud SCC) y Chronicle incluyen funcionalidades de UEBA, permitiendo identificar comportamientos anómalos y actividades sospechosas en el	En Azure, Microsoft Sentinel ofrece capacidades de UEBA integradas, utilizando IA para analizar actividades de usuarios y dispositivos, identificando patrones sospechosos en

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 35 de 36	TLP: BLANCO

	entorno de Google Cloud.	tiempo real.
Monitoreo proactivo y respuesta automáticas a eventos		
AWS	GCP	AZURE
Configuración de Monitoreo y Respuesta en AWS, Azure y GCP: En AWS, GuardDuty permite la detección temprana de amenazas y se puede integrar con AWS Lambda para activar respuestas automáticas, como la revocación de permisos o la suspensión de actividades sospechosas.	En GCP, Security Command Center permite configurar políticas de respuesta automática y alertas en tiempo real para responder de inmediato a actividades sospechosas o comportamientos anómalos en los recursos de Google Cloud.	En Azure, Azure Security Center ofrece capacidades de monitoreo en tiempo real y respuesta automática, integrándose con Logic Apps para automatizar acciones correctivas según el tipo de amenaza detectada.
Prueba de penetración y auditorías de terceros		
AWS	GCP	AZURE
Prácticas en AWS, Azure y GCP: AWS: Proporciona un entorno seguro para pruebas de penetración, y los clientes pueden solicitar permisos específicos para realizar estas pruebas en sus entornos.	GCP: Google ofrece pautas específicas para pruebas de penetración en su infraestructura y soporta la realización de auditorías por terceros en entornos de cliente.	Azure: Permite realizar pruebas de penetración siempre y cuando se cumplan los requisitos de Microsoft. También se pueden utilizar herramientas de auditoría para verificar la conformidad.
Simulación de ataques y red teaming		
AWS	GCP	AZURE
Ofrece soporte para simulaciones de ataques y herramientas como AWS Inspector para la identificación de vulnerabilidades en los entornos de nube.	Google Cloud Security Command Center y Chronicle permiten a los equipos de seguridad analizar patrones de comportamiento y responder a simulaciones de ataques en el entorno de nube.	Microsoft Defender for Cloud ayuda en la simulación de amenazas y permite monitorear la eficacia de la defensa frente a ataques simulados.
Asignación de contraseña expiradas y reasignación de contraseñas		
AWS	GCP	AZURE
AWS Trusted Advisor: Proporciona recomendaciones de seguridad, rendimiento y optimización de costos, ayudando a los clientes a mejorar la configuración de sus recursos de nube.	GCP Recommender: En GCP, Recommender brinda recomendaciones para optimizar la seguridad, el rendimiento y el costo de los recursos de nube.	Azure Advisor: Ofrece sugerencias específicas sobre configuración de seguridad, alto rendimiento y recuperación ante desastres, asegurando que las aplicaciones cumplan con las mejores prácticas de seguridad.
Implementación de Tokenización		
AWS	GCP	AZURE

POLÍTICA DE SEGURIDAD PARA ENTORNOS DE NUBE PUBLICA					
	Sistema de Gestión de Seguridad de la Información – Nivel Central				
	MINISTERIO DE SALUD	ID: PS-NC-022	Versión: 1	Página 36 de 36	TLP: BLANCO

En AWS, se pueden usar servicios como AWS DynamoDB para almacenar tokens generados y vincularlos a los datos originales mediante permisos estrictos de acceso, asegurando que solo usuarios autorizados puedan revertir la tokenización.	En GCP, se pueden emplear funciones de enmascaramiento y tokenización en BigQuery y otros servicios de Google Cloud para crear copias de datos enmascarados, asegurando la privacidad sin comprometer la funcionalidad para análisis de datos.	En Azure, Azure SQL Database permite implementar enmascaramiento dinámico de datos (Dynamic Data Masking), lo que asegura que los datos sensibles estén ocultos de usuarios no autorizados en tiempo real.
Cifrado de datos		
AWS	GCP	AZURE
En AWS, el AWS Key Management Service(KMS)permite administrar y cifrar datos en reposo en servicios como S3, RDS y EBS. Para datos en tránsito, se deben usar conexiones seguras mediante TLS/SSL con la versión 1.3.	En GPC, el Google Cloud Key Management Service (KMS) permite gestionar claves y cifrar datos en reposo en servicios como Google Cloud Storage y BigQuery, con TLS/SSL con la versión 1.3 para comunicaciones seguras en tránsito.	En Azure, el Azure Key Vault gestiona y cifra datos almacenados en Blob Storage, SQL Database,y otros servicios, además de asegurar las comunicaciones con TLS/SSL con la versión 1.3 para la transmisión de datos.